

CASO DE DISCUSIÓN

Ataque de Ransomware a Hospitales durante la pandemia COVID-19

Contexto general

Durante la pandemia de COVID-19, los hospitales y centros de salud se convirtieron en objetivos prioritarios para grupos de ciberdelincuentes debido a la alta dependencia tecnológica, presión operativa y necesidad de disponibilidad continua de los servicios médicos.

En octubre de 2020, diversos hospitales en Europa y Estados Unidos fueron víctimas de ataques de ransomware que paralizaron servicios clínicos críticos. Los atacantes aprovecharon vulnerabilidades tecnológicas, configuraciones inseguras y errores humanos para comprometer la infraestructura hospitalaria.

Uno de los casos más representativos ocurrió en un consorcio hospitalario ficticio denominado:

“Red Salud Integral” (RSI)

La organización administraba:

- 12 hospitales,
- 35 clínicas,
- más de 8,000 empleados,
- y aproximadamente 2 millones de historias clínicas electrónicas.

La institución contaba con:

- sistemas HIS (Hospital Information System),
- telemedicina,
- laboratorio digital,
- plataformas cloud,
- dispositivos IoMT (Internet of Medical Things),
- VPN para trabajo remoto,
- y servicios tercerizados.

Situación del incidente

Fase 1: Acceso inicial

Un colaborador del área administrativa recibió un correo aparentemente legítimo del “Ministerio de Salud”, con el asunto:

“Actualización urgente de protocolos COVID-19”

El correo incluía un archivo Excel malicioso.

El usuario abrió el archivo y habilitó macros.

Esto permitió instalar malware tipo loader que estableció conexión con servidores externos.

Fase 2: Movimiento lateral

Los atacantes descubrieron que:

- varios servidores Windows tenían parches desactualizados,
- existían cuentas administrativas compartidas,
- no se utilizaba MFA,
- la red hospitalaria no estaba segmentada,
- y el monitoreo SOC era limitado.

Durante 12 días los atacantes permanecieron ocultos dentro de la red.

Accedieron a:

- servidores clínicos,
- base de datos de pacientes,
- sistema de imágenes médicas,
- directorio activo,
- y respaldos conectados en línea.

Fase 3: Ataque ransomware

El ransomware fue activado simultáneamente en:

- hospitales,
- laboratorios,
- sistemas de emergencias,
- y servicios administrativos.

Consecuencias:

- historias clínicas inaccesibles,
- cancelación de cirugías,
- ambulancias desviadas,
- caída del sistema de telemedicina,
- retraso en atención de pacientes críticos.

Los atacantes exigieron:

- USD 8 millones en criptomonedas.

Además amenazaron con publicar:

- datos personales,
- diagnósticos médicos,
- información financiera,
- y contratos institucionales.

Impacto organizacional

Impacto operacional

- Paralización de operaciones por 9 días.
- Atención manual en emergencias.
- Suspensión de 4,500 citas médicas.
- Caída de sistemas de laboratorio clínico.

Impacto financiero

- Pérdidas estimadas: USD 25 millones.
- Costos de recuperación tecnológica.
- Multas regulatorias.
- Servicios externos de ciberseguridad.

Impacto reputacional

- Pérdida de confianza ciudadana.
- Cobertura negativa en medios.
- Investigaciones regulatorias.

Impacto legal

- Posible incumplimiento de normas de protección de datos.
- Demandas colectivas de pacientes.

Información adicional para análisis

Activos críticos involucrados

Activo	Criticidad
Historias clínicas electrónicas	Muy Alta
Sistema de emergencias	Muy Alta
Base de datos de pacientes	Muy Alta
Infraestructura de red	Alta
Plataforma de telemedicina	Alta
Servidores de respaldo	Alta
Equipos médicos conectados (IoMT)	Alta

Vulnerabilidades identificadas

N.º	Vulnerabilidad	Riesgo asociado
1	Falta de MFA	Acceso no autorizado
2	Parches desactualizados	Explotación de vulnerabilidades
3	Cuentas compartidas	Escalamiento de privilegios
4	Red no segmentada	Movimiento lateral
5	Backups conectados	Cifrado de respaldos
6	Baja capacitación del personal	Phishing exitoso

Controles inexistentes o insuficientes

- Gestión de vulnerabilidades débil.
- Ausencia de Zero Trust.
- Monitoreo limitado del SOC.
- Escasa concientización del personal.
- Falta de simulacros de incidentes.
- No existía un plan maduro de continuidad del negocio.

Objetivo del caso

Analizar cómo la gestión de riesgos de ciberseguridad permite:

- identificar amenazas,
- evaluar vulnerabilidades,
- estimar impactos,
- priorizar riesgos,
- y establecer controles preventivos.

Preguntas para desarrollar

Pregunta 1

¿Qué activos críticos de información y tecnológicos estaban en mayor riesgo durante el incidente?

Pregunta 2

¿Qué amenazas y vulnerabilidades permitieron el éxito del ataque ransomware?

Pregunta 3

¿Qué principios de la triada CIA (Confidencialidad, Integridad y Disponibilidad) fueron afectados?

Pregunta 4

¿Qué controles de seguridad alineados a ISO/IEC 27001 o NIST RMF pudieron reducir el riesgo?

Pregunta 5

¿Cómo la gestión de riesgos y la continuidad del negocio pudieron anticipar o reducir el impacto del incidente?